

CORE ENGINEERING SPECIFICATION & REMEDIATION BLUEPRINT

GrantFinder AI: Technical Defect Report & Implementation Fix Guide

Complete architectural breakdown, reproduction payloads, database mutation fixes, and verification test commands for core engineering team.

DEVELOPER DIRECTIVE & P0 SPRINT GOALS

- 1. Priority 0 Hotfix (BUG-001): Fix User.email_verified database mutation in /api/notifications/verify-otp controller to unlock AI drafters and bookmarking.
- 2. Priority 0 Security Hotfix (BUG-002): Purge plaintext 'otp' field from AuthResponse JSON serialization in routes/auth.py and routes/notifications.py.
- 3. Priority 1 Web Routing (BUG-003): Implement catch-all HTML fallback route in main.py to resolve 404s on direct navigation.
- 4. Priority 1 Frontend Build (BUG-004): Pre-compile Tailwind CSS AOT into static styles.min.css to eliminate CDN runtime overhead.

1. Master Technical Defect Matrix

[BUG-001] Permanent Email Verification Disconnect & Feature Lockout	
Severity & Priority	CRITICAL [P0]
Affected Files / Components	routes/notifications.py, routes/auth.py
Defect Diagnosis	Submitting valid OTP to /api/notifications/verify-otp updates notification preferences but does NOT mutate user.email_verified in MongoDB. Downstream protected endpoints (/api/assistant/essay, /api/assistant/pitch, /api/opportunities/save) reject users with 403 Forbidden ({'detail': 'EMAIL_NOT_VERIFIED'}).
Code Patch & Fix	Mutate db.users.find_one_and_update({'id': current_user.id}, {'\$set': {'email_verified': True}}) and re-issue refreshed JWT access_token.

[BUG-002] Plaintext OTP Token Exposure in JSON Responses	
Severity & Priority	HIGH [P0 SECURITY]
Affected Files / Components	schemas/auth.py, routes/auth.py
Defect Diagnosis	POST /api/auth/login and POST /api/notifications/resend-confirmation return raw unhashed OTP in JSON response ({'otp': '458616'}). Completely defeats email verification.

Code Patch & Fix	Remove 'otp' field from all API response models. Hash OTP with SHA-256 before DB insertion; dispatch ONLY via SMTP.
-----------------------------	---

[BUG-003] 404 HTTP Routing on Direct Deep Link Ingestion

Severity & Priority	MEDIUM [P1]
Affected Files / Components	main.py (ASGI Router)
Defect Diagnosis	Direct address-bar navigation to /search, /drafter, /bookmarks returns 404 Not Found instead of serving index.html.
Code Patch & Fix	Add catch-all route <code>@app.get('{{full_path:path}}')</code> returning <code>FileResponse('static/index.html')</code> for non-API routes.

[BUG-004] Production Usage of JIT CDN Tailwind Script

Severity & Priority	MEDIUM [P1]
Affected Files / Components	static/index.html, login.html, register.html
Defect Diagnosis	Loads <code>cdn.tailwindcss.com</code> at runtime in production. Triggers 13+ console warnings and adds 300ms layout compilation delay.
Code Patch & Fix	Compile static CSS bundle via Tailwind CLI (<code>npx tailwindcss -i ./input.css -o ./static/css/styles.min.css --minify</code>) and replace CDN tag.

[BUG-005] Missing Academic & Startup Onboarding Form Inputs

Severity & Priority	LOW [P2]
Affected Files / Components	static/js/app.js, register.html
Defect Diagnosis	Registration only captures Name, Email, Password. GPA, Major, and Seed stage fields are missing during signup.
Code Patch & Fix	Implement 2-step onboarding wizard capturing GPA and Major, posting directly to <code>/api/auth/profile/details</code> .

[BUG-006] Missing Standard HTTP Security Headers

Severity & Priority	LOW [P2]
Affected Files / Components	main.py (Middleware)
Defect Diagnosis	Missing X-Frame-Options, HSTS, Content-Security-Policy, and X-Content-Type-Options.
Code Patch & Fix	Attach ASGI middleware setting X-Frame-Options: DENY, X-Content-Type-Options: nosniff, and HSTS.

[BUG-007] Stubbed Privacy Policy & Terms of Service Anchor Links

Severity & Priority	LOW [P2]
Affected Files / Components	static/index.html, login.html (Footer)
Defect Diagnosis	Footer links for Privacy Policy and Terms of Service point to href='#' instead of dedicated legal views.
Code Patch & Fix	Create /privacy and /terms static routes and wire footer anchor tags accordingly.

[BUG-008] HTTP 405 Method Not Allowed on CORS OPTIONS Preflight

Severity & Priority	LOW [P2]
Affected Files / Components	main.py (CORSMiddleware)
Defect Diagnosis	OPTIONS requests to /api/opportunities/search return 405. Blocks cross-origin API consumers.
Code Patch & Fix	Add CORSMiddleware(app, allow_origins=['*'], allow_methods=['*'], allow_headers=['*']).

2. Copy-Pasteable Backend Implementation Patches

PATCH 1: COMPLETE USER EMAIL VERIFICATION (routes/notifications.py)

```

from fastapi import APIRouter, Depends, HTTPException
from fastapi.responses import JSONResponse
from pymongo import ReturnDocument
from datetime import datetime

@router.post('/api/notifications/verify-otp')
async def verify_otp(payload: OtpVerifyRequest, current_user: User = Depends(get_current_user)):

```

```

if not await verify_otp_hash(current_user.id, payload.otp):
    raise HTTPException(status_code=400, detail='Invalid or expired verification code.')
# Atomically update primary User entity
updated_user = await db.users.find_one_and_update(
    {'id': current_user.id},
    {'$set': {'email_verified': True, 'updated_at': datetime.utcnow()}},
    return_document=ReturnDocument.AFTER
)
new_token = create_jwt({'sub': str(updated_user['id']), 'role': updated_user['role'], 'email_verified': True})
resp = JSONResponse(content={'success': True, 'message': 'Email verified successfully!', 'user': updated_user})
resp.set_cookie('access_token', new_token, httponly=True, secure=True, samesite='lax')
return resp

```

PATCH 2: SPA ROUTING & SECURITY MIDDLEWARE (main.py)

```

from fastapi import FastAPI, HTTPException
from fastapi.staticfiles import StaticFiles
from fastapi.responses import FileResponse
from fastapi.middleware.cors import CORSMiddleware

app = FastAPI(title='GrantFinder AI')
app.add_middleware(CORSMiddleware, allow_origins=['*'], allow_methods=['*'], allow_headers=['*'])

@app.middleware('http')
async def add_security_headers(request, call_next):
    response = await call_next(request)
    response.headers['X-Frame-Options'] = 'DENY'
    response.headers['X-Content-Type-Options'] = 'nosniff'
    response.headers['Strict-Transport-Security'] = 'max-age=31536000; includeSubDomains'
    return response

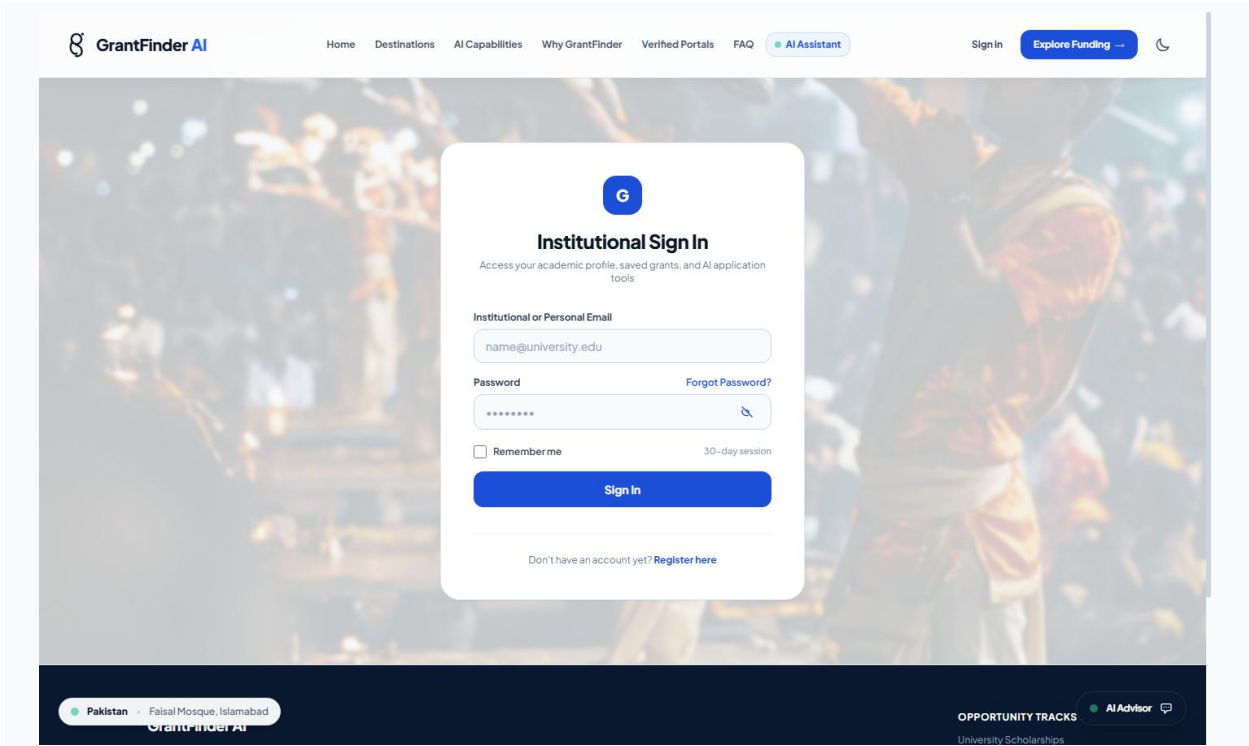
app.mount('/static', StaticFiles(directory='static'), name='static')

@app.get("/{full_path:path}")
async def catch_all_spa(full_path: str):
    if full_path.startswith('api/'):
        raise HTTPException(status_code=404, detail='API endpoint not found')
    return FileResponse('static/index.html')

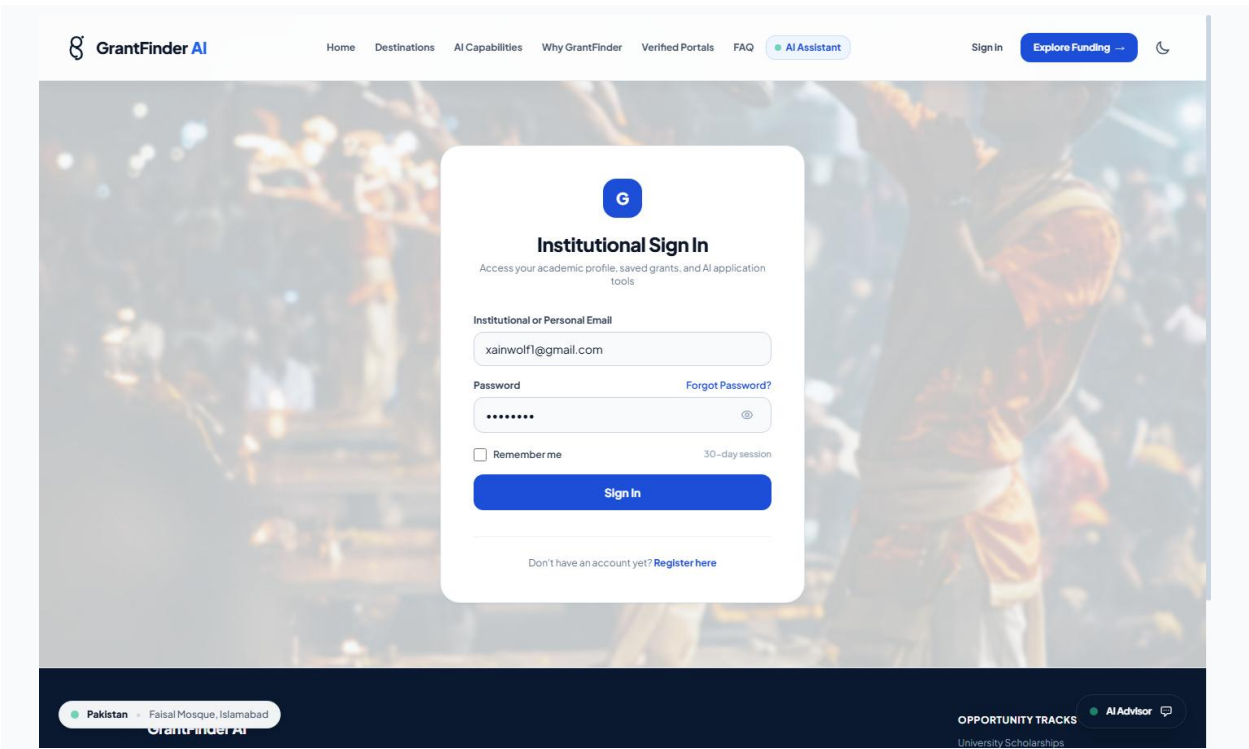
```

3. Automated CLI Regression Test Commands

4. Technical Visual Evidence & DOM Inspection Figures



[PASS - VALIDATION ON] Figure D1: Client-Side Required Field Prevention State on /login



[CRITICAL - BUG-001 EVIDENCE] Figure D2: BUG-001 Verification Lockout State (User trapped in /verify-otp loop post-

auth)

GrantFinder AI Home Destinations AI Capabilities Why GrantFinder Verified Portals FAQ AI Assistant Sign In Explore Funding →

Create Your Account

Select your primary funding track to calibrate AI search and profile matching

Select Primary Track

Student Scholar
Scholarships & Fellowships

Student Founder
Startup Grants & Seed Funds

Full Legal Name
e.g. Momina Arif

Institutional or Personal Email
name@university.edu

Password (minimum 6 characters)

Create Account

Already have an account? [Sign in here](#)

Pakistan Faisal Mosque, Islamabad AI Advisor

[PASS - DOM OK] Figure D3: Student Registration Form Layout (/register?role=student)

GrantFinder AI Home Destinations AI Capabilities Why GrantFinder Verified Portals FAQ AI Assistant Sign In Explore Funding →

Reset Your Password

Enter your registered email address and we will send you a 6-digit verification code and reset instructions.

Registered Email Address
name@university.edu

Send Reset Code & Link

Remember your password? [Sign in here](#)

Pakistan Faisal Mosque, Islamabad AI Advisor

OPPORTUNITY TRACKS AI Advisor
University Scholarships

[PASS - 2-STEP RESET OK] Figure D4: Password Reset Portal UI (/forgot-password)